



ASSESSMENT 3
RISK ASSESSMENT AND CONTINGENCY PLAN
Security Management Plan for InnovateTech Solutions

Subject: Information Security Management (MITS)

Group:SG 03

Prepared for: Dr Emily Clarke, Co-Founder, and the Executive Management Team

Prepared by: Nazia Ahmed (65883), Md Ajhar Mia (65281), Kaushik Das (64280),
Anika Tabasshum (64284), Akash Adhikary (63516), Ariful Islam Emon (65271)

Table of Contents

Executive Summary	3
1. Introduction.....	3
2. Formal Security Approach and Governance Fit	3
3. Security Management Plan Model.....	4
4. Threats, Vulnerabilities, Attacks and Risk Analysis	5
5. Continuity Plan and Business Continuity Plan	6
6. Legal and Statutory Requirements	7
7. Cost-Benefit Analysis of the Proposal.....	8
8. Conclusion	9
Sign-off Page	9
References.....	9

Executive Summary

The following report is for the Executive Management Team of InnovateTech Solutions and for the attention of Dr Emily Clarke. Evaluates the security risk associated with the proposed acquisition(s) in foreign countries and/or foreign offices, including secure migration of data, network interoperability and cross-border privacy policy compliance. Untrusted acquired networks, cloud misconfiguration, ransomware, and unlawful transfer of personal information, credential theft and loss of proprietary AI assets are identified as priority risks. Approval for operating security management plan in compliance with ISO/IEC 27001, to have a gated integration, to have strong IDs control, central monitoring, incident reporting and a tested recovery before connecting with any production system or migrating production data.

1. Introduction

InnovateTech is an Australian AI and Analytics SME employing 75 SME staff across disparate locations and operating with customers in over 150 countries in Finance, Healthcare and retail. It is aiming to establish two overseas offices and is acquiring two overseas AI firms. Therefore this report concentrates on how to securely integrate acquired environments, while maintaining the continuity of services, client information and proprietary algorithms.

A Risk Management Plan becomes an organized management plan when you take various individual skill sets and turn them into the following steps: Identify Assets and Data Flows; Identify Threats and Weaknesses; Rate likelihood and impact; Select treatment, owners, evidence; Approve residual risk; then Monitor and Review. Contingency planning is essential since no useful control can get rid of outage or breach risk. Risk analysis is used to focus scarce resources and cost-benefit analysis helps to make sure that controls are retarded only if justified to support rapid innovation.

Planning should be started prior to each new firm joining the corporate environment and until post-integration assurance is accepted for this acquisition programme. Success is evidenced by authorised data transfers, resolved high risk issues, test of recovery, and documented management decision making and traceable decisions, rather than by the opinion of individual specialists.

2. Formal Security Approach and Governance Fit

It is recommended to adopt a formal approach in the form of an Information Security Management System (ISMS) based on ISO/IEC 27001 with the outcomes of the NIST CSF 2.0 as a governance and operations organising framework [1] [2]. Innovative Ai services are commercially trustworthy because protecting the privacy of the client and research IP is part of InnovateTech's mission.

All risk appetite and any high risk residual should be discussed at, and approved by, a Security Steering Committee, chaired by Dr Clarke. David is responsible for maintaining the risk register and handling incidents, while Liam is responsible for cloud security and testing with restore, Sarah is responsible for network segmentation and access control, and Maria approves of access to research data.

Exceptions to the policy must be for sound business as a reasonable and valid exception, must have compensating controls, an expiration date and must be approved at the executive level. This design resolves engineers' worry about too many bureaucratic procedures: low-risk research experimentation is not slowed down, but anything done to production data, privileged identities or risk of international transfer is documented and can be held to account. For this accountability Figure 1 displays the governance framework utilized.

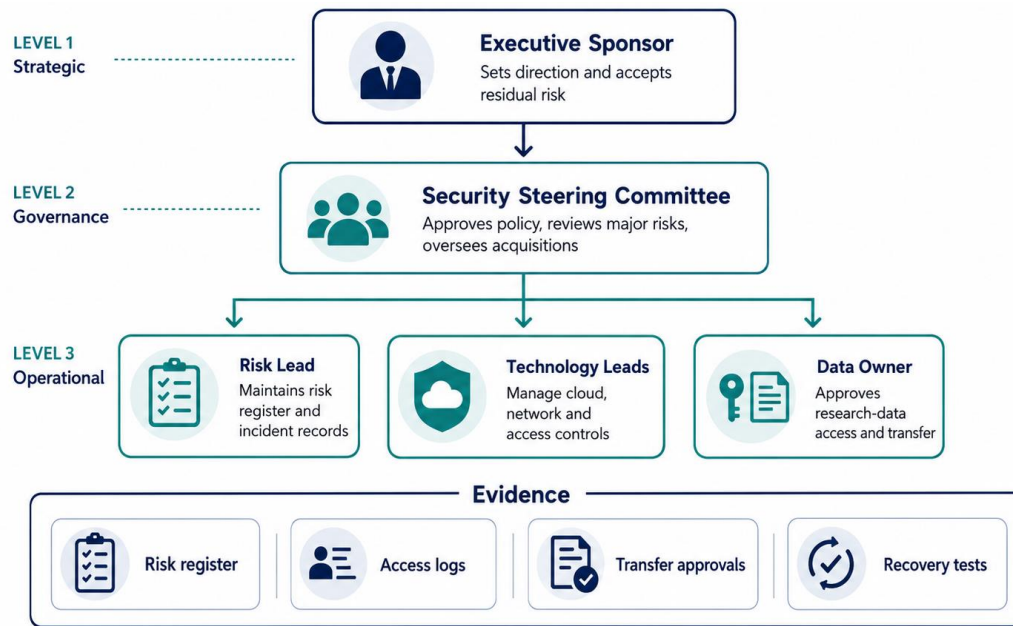


Figure 1. Security governance structure for InnovateTech Solutions. Source: Authors.

3. Security Management Plan Model

For every acquired firm, there should be a controlled integration process. Pre-connection due diligence manifests assets, identities, repositories and cloud tenants, categories of data, contractual restrictions and critical vulnerabilities, previous incidents. The acquired network is then segmented and separated from production with identities reset, multifactor authentication and privileged access management locked on, and endpoint evaluation and the attachment of only allowed services.

Only once data has been classified, transfer authority verified, encrypted, checked for malware and secrets scanning, integrity verified, backed up and approved by data-owner can migrations proceed. Central monitoring of log information from the Integration Zone, as well as cloud platforms and endpoints. Any inconsistencies/exceptions and any residual risks are reported to the management within 90 days of the acquisition.

There are three gates in implementation. Connectivity cannot happen without due diligence; verification cannot happen without passing; and assurance cannot be accepted without passing; and inherited systems cannot be accepted as if they were normal operations. Access logging, integrity checking and rollback must be shown in a test migration. Once the migration is implemented, temporary privileges are eliminated, open vulnerabilities are retested and any accepted residual risk is signed by the business owner. The control owners and evidence are provided in Table 1 and the secure acquisition integration process is depicted in Figure 2.

Table 1. Control Ownership and Required Evidence

Control domain	Required action	Owner / evidence
Governance	Monthly acquisition-risk review and exception register.	Dr Clarke / minutes
Identity and network	MFA, privileged-access control and isolated integration zone.	Sarah and Liam / logs
Data migration	Classification, encryption, integrity check and approval gate.	David and Maria / record

Control domain	Required action	Owner / evidence
Monitoring and recovery	Central alerts and immutable backup restore test.	David and Liam / test report

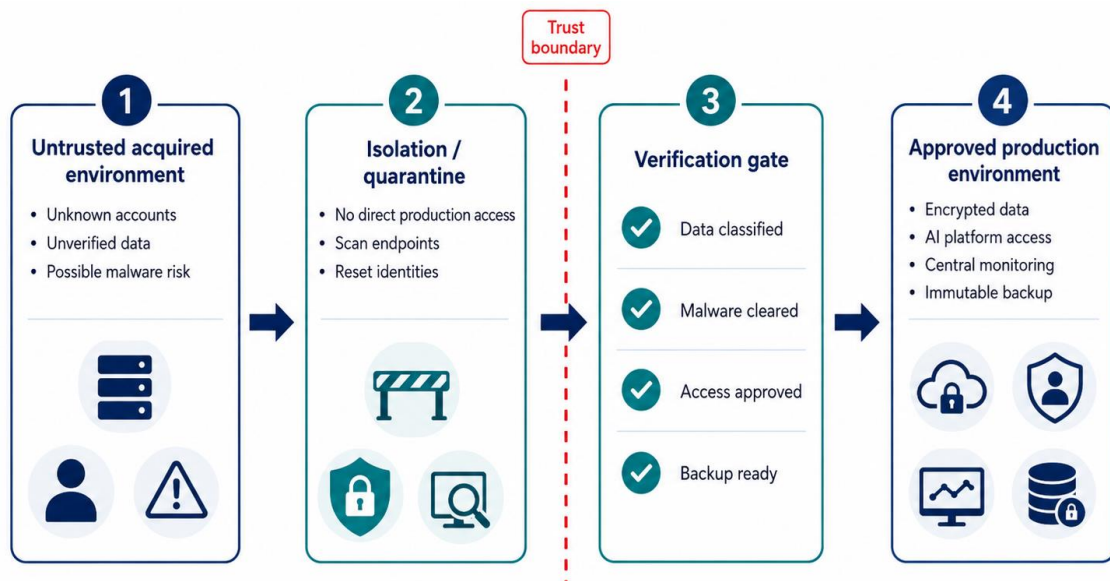


Figure 2. Secure acquisition integration process. Source: Authors.

4. Threats, Vulnerabilities, Attacks and Risk Analysis

A 5×5 likelihood-impact method is used: 1–4 Low, 5–9 Medium, 10–14 Significant and 15–25 High. The production connection/migration may not be implemented until a high risk has been evaluated and treated by the executive. Incident statistics in Figure 3 are planning estimates for prioritisation and not historical.

Unauthorized migration, public cloud exposure, ransomware movement on an acquired network, privacy breach, credential compromise and model or sourcecode exfiltration are the principle attacks. The following controls respond to vulnerabilities which make those attacks feasible.

Until there is evidence of required treatments, R1 - R4 are not acceptable. R5 and R6 need to be treated before the possibility of wider access to client datasets or repositories. Evidence shall consist of Access-review output, Security-alert coverage report and Vulnerability retest result, Approved-transfers record, Successful restore-test results, and Report any that are missing as an open risk.

The following are integration review times: Weekly until the migration is complete, monthly for the first 90 days after the connection, and quarterly after that. Initial treatments are being continuously reviewed in response to an incident, material architecture change or new regulatory requirement for its continued relevance with the evolving operating environment. Table 2 is a summary of the risk register and risk treatment priorities.

Table 2. Risk Register and Treatment Priorities

Risk / attack	Vulnerability	Inherent	Treatment	Residual
R1 Unauthorised migration	Rushed, unclassified transfer	20 High	Encrypt; validate; approve; log	8 Medium

Risk / attack	Vulnerability	Inherent	Treatment	Residual
R2 Cloud data exposure	Misconfigured storage or IAM	16 High	Least privilege; review; DLP	6 Medium
R3 Ransomware spread	Untrusted acquired endpoints	15 High	Segment; EDR; patch; backup	6 Medium
R4 Unlawful transfer	Unclear jurisdiction/data map	15 High	PIA/DPIA; terms; approval	6 Medium
R5 Credential theft	Phishing/shared privilege	12 Significant	MFA; PAM; conditional access	4 Low
R6 Model/IP exfiltration	Excess repository access	10 Significant	RBAC; monitoring; NDA	4 Low

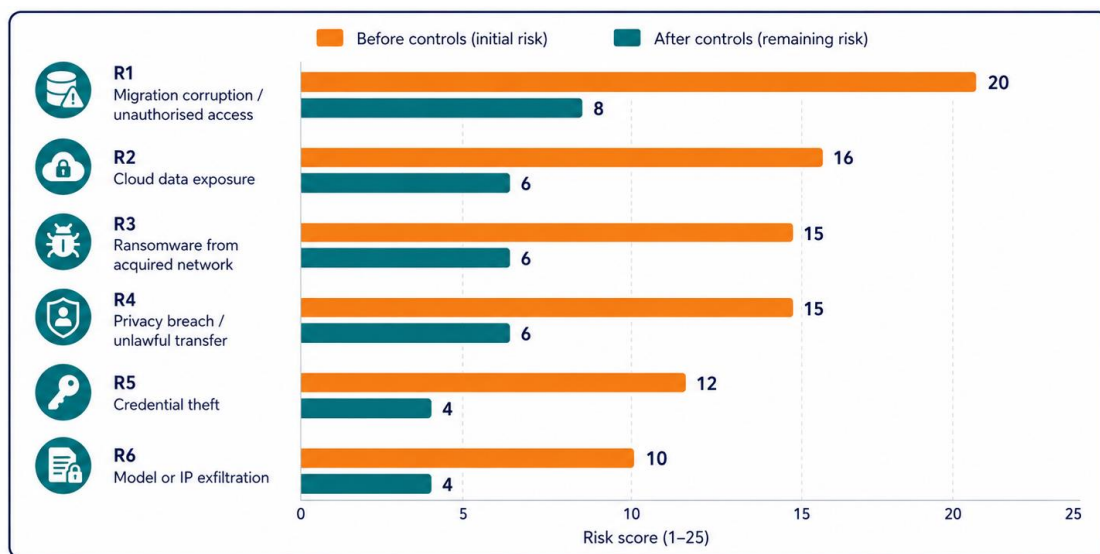


Figure 3. Planned risk reduction after controls on a 5 × 5 scale. Source: Authors.

5. Continuity Plan and Business Continuity Plan

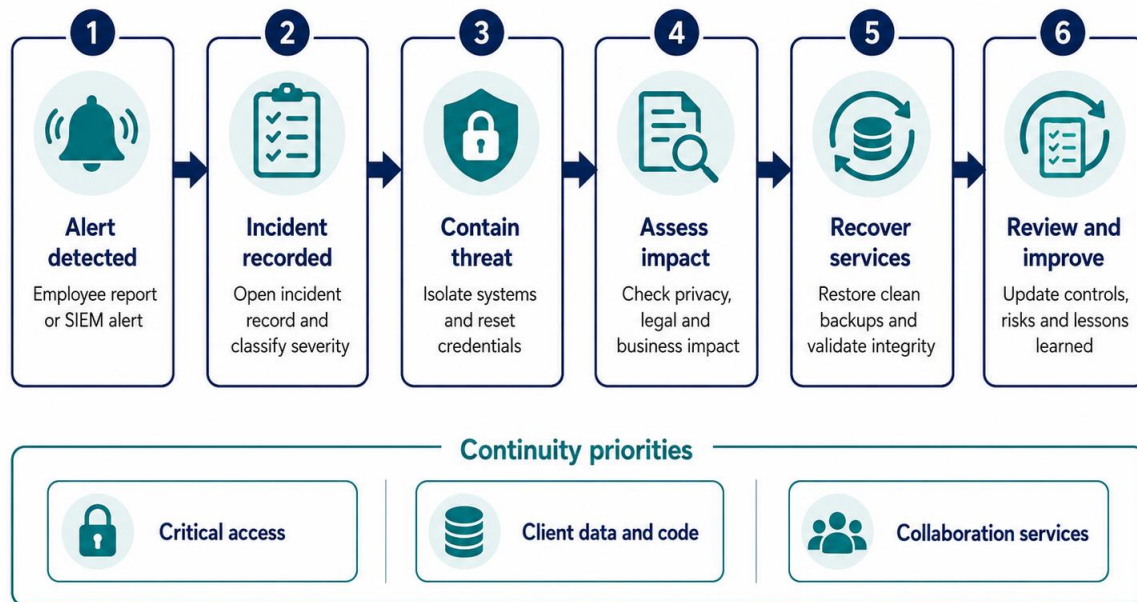
Incident Reporting starts when a staff member (or provider/monitor) suspects activity. Reporter documents Time, System, Evidence, and Suspected Data; David prioritizes and notifies the Incident Lead. InnovateTech demarcates impacted assets, supports data isolation, logs data, identifies who has to be notified and notifies approved clients during a major incident.

Technology will be restored first based upon the continuity plan through clean identity and secure-access services, then client datasets and code repositories will be restored, followed by collaboration and non-critical research services.

Target recovery times are four hours for identity and ZTNA, eight hours for active client data lakes and code repositories and 24 hours for collaboration and non-critical research platforms. The business continuity plan maintains delivery services by working remotely, using an agreed alternate communications route, triaging priority clients and manually granting access to urgent clients. There is one designated spokesperson, who helps to coordinate statements with the advice of experts on privacy and legal issues. An after acquisition practice and practices twice a year that verify roles, Recovery evidence and communications. Continuity Targets are listed in Table 3 and the flow chart of Table 4 illustrates the Incident response workflow and priorities.

Table 3. Continuity Actions and Recovery Targets

Disruption	Immediate continuity response	Target
Cloud data lake breach	Revoke keys; isolate dataset; preserve evidence.	Contain: 4 h
Ransomware in acquired firm	Disconnect integration zone; recover clean data.	Critical service: 24 h
Collaboration outage	Use approved alternate communication channel.	Alternate work: 2 h

*Figure 4. Incident response workflow and continuity priorities. Source: Authors.*

6. Legal and Statutory Requirements

InnovateTech is an Australian business, and should adhere to the Australian Privacy Principles. APP 8 – reasonable measures are required before handing on to an overseas recipient, APP 11 – reasonable handling in relation to personal information is required [3]. Any suspected eligible breaches are to be evaluated and if necessary reported as part of the Notifiable Data Breaches scheme [4].

If Security, GDPR security, international-transfer safeguards and data protection impact assessment requirements are applicable, they should be considered for acquired firms and client datasets that contain EU personal data [5]. When there is a nexus to California personal information, CCPA/CPRA rights and contractual requirements need to be covered [6]. Before data transfer individual local laws in the jurisdictions chosen for acquisition must be examined.

Therefore, every acquisition should have its own data inventory, a retention/review log for the purposes of processing it, an assessment of how the data will be transferred and a record of any processor breaches and decisions. The provision of production personal information to overseas group companies or providers is made only after the transfer path, security safeguards and accountable owner approval has been documented. The legal obligations are summarised below in table 4, and the cross-border transfer decision path is shown below in figure 5.

Table 4. Legal Obligations and Security Response

Obligation	Application	Plan response
APP 8 / APP 11 / NDB	Australian personal information and overseas disclosure.	Safeguards, transfer review and breach playbook.
GDPR, if applicable	EU personal data processed or transferred.	Transfer safeguards; DPIA where high-risk.
CCPA/CPRA, if applicable	California-linked personal information in scope.	Data inventory, notice and rights process.

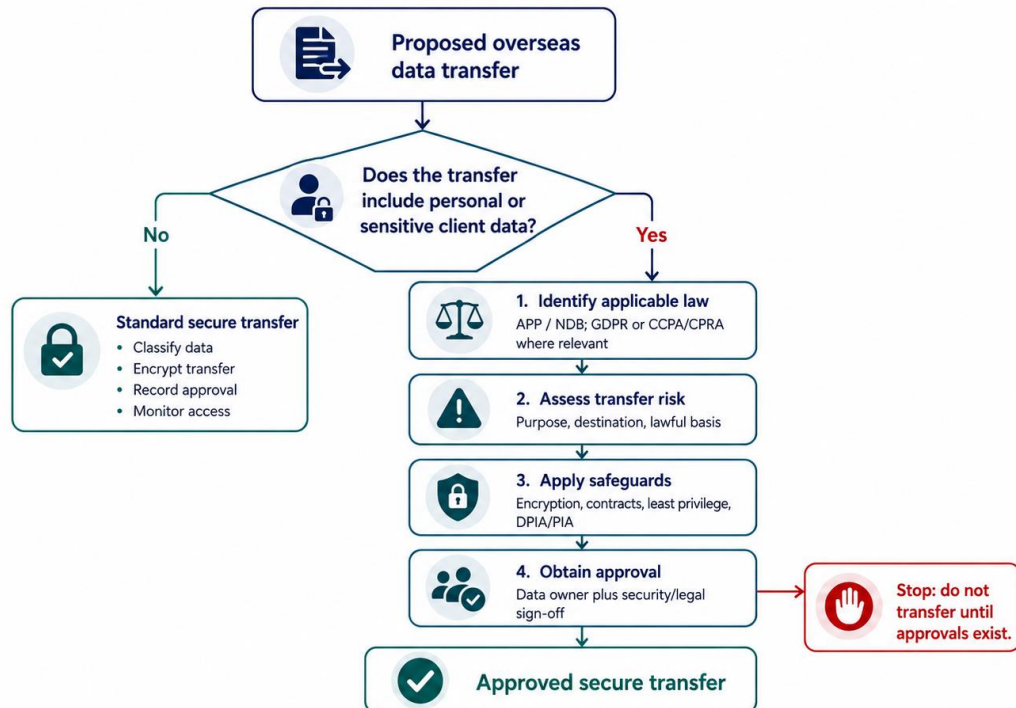


Figure 5. Cross-border data transfer decision path. Source: Authors.

7. Cost-Benefit Analysis of the Proposal

The proposal is to enhance the current hybrid-cloud and ZTNA configurations instead of supplanting them. Identity hardening and segmentation mitigate risk of access and lateral-movement opportunities prior to connectivity; monitoring to shorten detection times; migration assurance and privacy review mitigate regulatory or contractual exposure; respect recovery testing reduces disruption. Money-back estimation is difficult without having vendor quotes and incident-loss data, and hence, the approvals should also be done in a phased manner, based on the integration gates, and checked for residual risk.

Eye on the benefits – measurable elements: High risks closed before connection, Privileged accounts reviewed, Migration – complete approval record, Incident containment time, Test successful restore. If there was no evidence, management may be able to postpone connecting or mandate, to perform corrective action, prior to incurring additional costs and risks.

The initial gate should include due diligence, identity/segmentation controls, the second gate should include monitored migration for applications and services, and the third gate should put a definitive end to the temporary exception, and confirm recovery tests and controls. Table 5 summarises the cost-benefit evaluation and Table 6 shows the group contribution statements.

Table 5. Cost-Benefit Evaluation

Investment area	Cost level	Expected benefit
Governance and privacy review	Medium	Auditable transfer and risk decisions.
Identity, PAM and segmentation	Medium–High	Reduced unauthorised access and lateral movement.
Monitoring and cloud posture	High	Earlier detection of misuse and exposure.
Backups, exercises and training	Medium	Reliable restoration and response.

Table 6. Group Members and Individual Contribution Statements

Student name	Student ID	Specific contribution
Nazia Ahmed	65883	Prepared the executive summary, values alignment and document quality review.
Md Ajhar Mia	65281	Developed the risk analysis, scoring method and risk-treatment recommendations.
Kaushik Das	64280	Prepared legal and cross-border privacy compliance analysis.
Anika Tabasshum	64284	Prepared incident reporting and continuity procedures.
Akash Adhikary	63516	Prepared cost-benefit analysis, figures and report formatting.
Ariful Islam Emon	65271	Prepared security controls, references and approval content.

8. Conclusion

Security management needs to be a continuous process as mergers, countries, client information and cloud offerings shift the dynamics of InnovateTech's risk. Controls are still effective – evidenced by a risk register reviewed and access reviewed, transfer approved and incident metrics/Restore tests successful. This controlled and governed method safeguards trust and IP for the client and enables global expansion and IP protected research and innovation.

Sign-off Page

This page records acceptance of the proposed Security Management Plan and its priority risk treatments. Table 7 provides the approval and sign-off record.

Table 7. Approval and Sign-off

Approval role	Name / position	Signature	Date
Prepared by	Group SG 03 Representative		
Reviewed by	Dr Emily Clarke, Co-Founder		
Approved by	Executive Management Representative		
Security owner acknowledgement	Data Security Analyst / nominated owner		

References

- [1] International Organization for Standardization, "ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection—Information security management systems—Requirements," 2022.
- [2] National Institute of Standards and Technology, "The Cybersecurity Framework (CSF) 2.0," NIST CSWP 29, Feb. 2024.
- [3] Office of the Australian Information Commissioner, "Australian Privacy Principles guidelines: Chapter 8 Cross-border disclosure of information and Chapter 11 Security of personal information," 2025.
- [4] Australian Information Commissioner's Office, "Data breach preparation and response," last modified Jun. 2024.
- [5] European Parliament and Council, Regulation (EU) 2016/679, General Data Protection Regulation, Apr. 2016.
- [6] California Department of Justice, "California Consumer Privacy Act (CCPA)," updated Mar. 13, 2024.